

BuySellChain

Sistema d'Asta Trustless su Blockchain Hyperledger Fabric

Thread Model BuySellChain

Salvucci Franco (Mat. 0368692)
Ionut Georgian Zbirciog (Mat. 0381279)

20 aprile 2026

Indice

1	Definizione dell'infrastruttura e delle Zone di Sicurezza	2
1.1	Zona DMZ (Demilitarized Zone)	2
1.2	Zona IT / Enterprise (Restricted Zone)	3
2	Asset Inventory e Analisi delle Criticità	4
3	Superficie Osservabile, Inferenza e Vettori di Attacco	5
4	Grafo dell'Infrastruttura e Flussi di Comunicazione	6
5	Dall'Architettura alla Baseline Comportamentale (Operating Envelope)	8
5.1	Definizione della Baseline Qualitativa	8
5.2	Finestra di Telemetria Osservata (Dataset di Esempio)	9
5.3	Valutazione Deviazioni e Classificazione	9
5.4	Debrief Finale di Sicurezza	10

1 Definizione dell'infrastruttura e delle Zone di Sicurezza

L'architettura di rete del sistema **BuySellChain** è stata progettata e segmentata seguendo i principi fondamentali dello standard internazionale IEC 62443. Questa suddivisione in zone logiche di sicurezza (Security Zones) e condotti di comunicazione (Conduits) permette di isolare i sistemi critici, limitare drasticamente i movimenti laterali di un eventuale attaccante in caso di compromissione perimetrale e applicare policy di accesso granulari basate sul principio del minimo privilegio (Least Privilege).

1.1 Zona DMZ (Demilitarized Zone)

La DMZ funge da livello cuscinetto tra la rete pubblica (Internet) e la rete interna strettamente confinata. Il suo scopo è ricevere, filtrare e sanitizzare tutte le richieste provenienti dall'esterno prima che queste possano raggiungere i sistemi di validazione e persistenza dei dati.

Componente		Descrizione e Funzione Architetturale
Reverse Proxy (es. NGINX)		Gestisce la terminazione TLS/SSL, isolando i server applicativi dall'esposizione diretta. Fornisce funzionalità di bilanciamento del carico e mitigazione base contro attacchi volumetrici (DDoS).
Security Gateway (Backend)		Server applicativo sviluppato in Python/Flask. Agisce come Policy Enforcement Point (PEP): valida i token JWT, implementa il controllo degli accessi (RBAC) e sanitizza gli input strutturali (JSON Schema) prima di invocare i comandi verso la blockchain.
Gestore delle Sessioni		Modulo integrato nel Gateway per l'emissione, la validazione e la revoca dei JSON Web Token (JWT), gestendo le transizioni di stato dell'autenticazione in modalità stateless.

Tabella 1: Componenti dell'infrastruttura situati nella Zona DMZ.

1.2 Zona IT / Enterprise (Restricted Zone)

Questa zona, non accessibile direttamente dall'esterno, ospita i motori di persistenza, il sistema di consenso decentralizzato e i dati sensibili. Le comunicazioni in ingresso sono consentite esclusivamente dal Security Gateway tramite protocolli e porte rigorosamente definiti.

Componente	Descrizione e Funzione Architetturale
Rete Hyperledger Fabric	Infrastruttura blockchain permissioned. Include gli <i>Orderer Nodes</i> (per l'ordinamento crittografico dei blocchi) e i <i>Peer Nodes</i> (per l'esecuzione dello Smart Contract e il mantenimento del Ledger distribuito).
Smart Contract (Chaincode)	Codice eseguibile all'interno della rete Fabric che incapsula la logica di business immutabile (es. vincoli di rilancio, finestre temporali delle aste, transizioni di stato dell'asset).
Client Lisp	Modulo software interno che agisce da intermediario tra il Security Gateway e la rete Fabric, occupandosi della firma delle transazioni tramite Membership Service Provider (MSP).
Database Off-Chain	Istanza PostgreSQL containerizzata. Mantiene la persistenza dei dati anagrafici (in conformità al GDPR), l'hash delle password (algoritmo bcrypt) e i mapping tra identità Web 2.0 e identità blockchain.

Tabella 2: Componenti dell'infrastruttura situati nella Zona IT / Enterprise.

2 Asset Inventory e Analisi delle Criticità

Il passo fondamentale per un'efficace modellazione delle minacce è l'identificazione e la classificazione degli asset. Di seguito vengono catalogati i componenti hardware, software e logici dell'infrastruttura BuySellChain. A ciascuno è assegnato un livello di criticità in base all'impatto di una potenziale violazione (in termini di disponibilità del servizio, integrità delle compravendite o riservatezza dei dati personali degli utenti).

Asset	Tipo	Criticità	Dipendenze e Relazioni
Smart Contract (Chaincode)	Software	Critica	Dipende direttamente dal meccanismo di consenso di Fabric. Una sua compromissione logica altera irreversibilmente l'esito delle aste.
Ledger Distribuito	Dati	Critica	Dipende dall'integrità dei Peer Nodes e dalle identità MSP. Contiene la <i>provenance</i> e la proprietà legale degli asset immobiliari.
Security Gateway (API)	Applicativo	Alta	Dipende dal DB Off-Chain per l'autorizzazione. È il singolo punto di ingresso logico (Single Point of Failure applicativo) verso la blockchain.
Database greSQL	Database	Alta	Dipende dall'ambiente Docker isolato e da SQLAlchemy. La sua violazione comporta un Data Breach di informazioni personali (GDPR) e l'esposizione degli hash delle password.
Chiave Segreta JWT	Crittografia	Estrema	Resiede in memoria nel Security Gateway. Se esfiltrata, permette a un attaccante di forgiare sessioni amministrative a piacimento (Elevation of Privilege totale).
Frontend Web (Client)	Interfaccia	Media	Dipende dalla disponibilità del Security Gateway. Vulnerabile ad attacchi lato client (XSS, CSRF) ma non contiene logica di business fidata.
API Catasto (Sistema Terzo)	Servizio Esterno	Alta	Dipende dall'ISP e dalle CA pubbliche. Utilizzato per certificare l'esistenza degli immobili; la sua indisponibilità blocca la creazione di nuove aste.

Tabella 3: Inventario dettagliato degli asset del sistema BuySellChain con mappatura delle dipendenze.

3 Superficie Osservabile, Inferenza e Vettori di Attacco

La superficie osservabile rappresenta tutto ciò che un potenziale attaccante o un analista può dedurre dall'esterno dell'infrastruttura semplicemente intercettando il traffico di rete, analizzando i metadati delle comunicazioni o interagendo con le interfacce pubbliche.

Mappare questi elementi è cruciale per comprendere quali informazioni il sistema espone (anche involontariamente) e come queste anomalie o deviazioni comportamentali possano fungere da indicatori per formulare ipotesi di attacco. La tabella seguente unifica le osservazioni della superficie con le relative inferenze e i vettori di minaccia derivati (in linea con la metodologia STRIDE).

Asset Target	Cosa si osserva (Sintomo)	Cosa si inferisce (Ipotesi)	Possibile Attacco (Minaccia)
Endpoint /auth/login	Picco anomalo di richieste POST (es. centinaia al secondo) provenienti da IP eterogenei o singole subnet.	L'attaccante sta testando liste di credenziali pre-esfiltrate o tentando di forzare una password.	Credential Stuffing o Brute Force (Spoofing).
Endpoint /bids	Aumento drastico del traffico HTTP negli ultimi 10 secondi di una finestra temporale d'asta.	Tentativo di saturare il server per impedire ad altri di rilanciare, o script automatizzati.	Sniper Bidding e Denial of Service (DoS) applicativo.
Security Gateway (API)	Rilevamento di caratteri di escape insoliti, cicli annidati o tentativi di iniezione nei payload JSON in ingresso.	L'attaccante cerca di bypassare il parser per eseguire comandi diretti sul client Lisp o sul DB.	Lisp Command Injection o SQL Injection (Tampering).
Sessioni Utente (JWT)	Modifica del payload codificato in Base64 del JWT (es. alterazione del campo <i>role</i> da <i>Bidder</i> a <i>Admin</i>).	Un utente malintenzionato sta testando la robustezza dell'algoritmo di firma HMAC del token.	Elevation of Privilege o Session Forgery .
API Catasto (Connessioni in uscita)	Traffico anomalo dal Security Gateway verso IP sconosciuti al di fuori dei domini governativi previsti.	Il Gateway è stato compromesso e sta esfiltrando dati, oppure è vittima di un attacco SSRF.	Server-Side Request Forgery o Data Exfiltration (Information Disclosure).
Frontend (Interfaccia)	Inserimento di tag HTML o script JavaScript nei campi descrittivi degli immobili in vendita.	Ricerca di vulnerabilità nella sanitizzazione lato server dei template Jinja2.	Cross-Site Scripting (XSS) e furto di token.

Tabella 4: Threat Model unificato: dalla superficie osservabile all'inferenza dell'attacco.

4 Grafo dell'Infrastruttura e Flussi di Comunicazione

Per agevolare l'analisi dei rischi e l'implementazione dei controlli di sicurezza, viene presentata la topologia dei flussi di rete. Questa scomposizione evidenzia i nodi di origine e destinazione, i confini di trust attraversati, i protocolli crittografici necessari e l'intensità fisiologica attesa per ciascun condotto (utile a stabilire una *baseline* comportamentale per i sistemi di Intrusion Detection).

Ogni deviazione da questi flussi autorizzati (ad esempio, il Database Off-Chain che tenta di iniziare una connessione verso Internet) deve essere considerata un'anomalia severa.

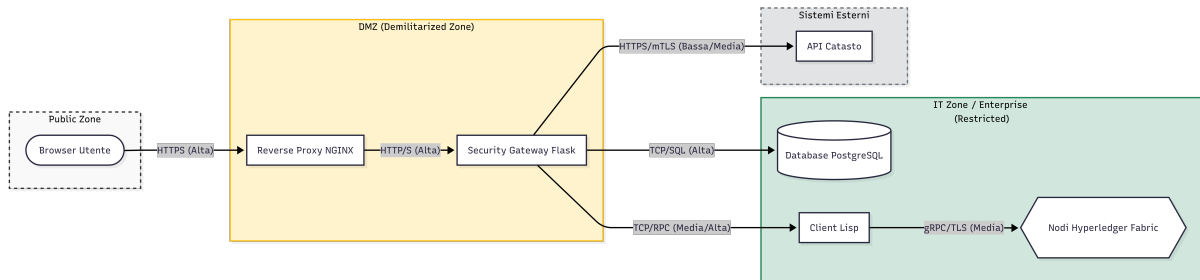


Figura 1: Grafo dell'infrastruttura

Sorgente	Destinazione		Protocollo	Frequenza	Motivazione / Logica di Business
Browser Utente	Reverse (DMZ)	Proxy	HTTPS	Alta	Navigazione piattaforma, consultazione grid aste, login e invio offerte. Traffico cifrato TLS 1.3.
Reverse Proxy	Security Gateway		HTTP/S	Alta	Inoltro delle richieste decifrate (o ri-cifrate internamente) verso il server Flask per l'elaborazione.
Security Gateway	Database (IT Zone)		TCP/SQL	Alta	Validazione credenziali, recupero RBAC, lettura/scrittura dati anagrafici off-chain tramite SQLAlchemy.
Security Gateway	Client (IT Zone)	Lisp	(IT TCP/RPC	Media/Alta	Traduzione delle chiamate REST in primitive (AddKV, GetKV) per l'interazione con la Blockchain.
Client Lisp	Nodi (IT Zone)	Fabric	(IT gRPC/TLS	Media	Invocazione dello Smart Contract, proposta di transazioni e interrogazione dello stato del Ledger.
Security Gateway	API Catasto (Ester- no)		HTTPS/mTLS	Bassa/Media	Chiamata sincrona per la certificazione e la validazione dei dati di un immobile in fase di creazione asta.

Tabella 5: Mappatura dettagliata dei flussi di comunicazione autorizzati (Conduits) tra gli asset.

5 Dall'Architettura alla Baseline Comportamentale (Operating Envelope)

L'obiettivo di questa fase è usare la topologia di BuySellChain per definire cosa costituisce un comportamento di rete *normale*. La normalità non è un punto singolo, ma un involucro operativo continuo (*operating envelope*). La classificazione degli eventi deve quindi distinguere tra **Normal**, **Deviazione Lieve**, **Deviazione Forte** e **Unknown**.

5.1 Definizione della Baseline Qualitativa

Le comunicazioni attese vengono modellate come relazioni lecite tra asset, con frequenza temporale e intensità prevista.

Relazione Normale	Quando	Intensità	Note
Frontend Web → Security Gateway	Sempre (Sì)	Alta	Navigazione utenti, login, invio offerte.
Security Gateway → DB Off-Chain	Sempre (Sì)	Alta	Validazione utenze, recupero RBAC, lettura dati GDPR.
Security Gateway → Rete Fabric (via Client Lisp)	Sempre (Sì)	Media	Invocazione Smart Contract per registrazione aste/offerte.
Security Gateway → API Catasto	Giorno/Notte (Sì)	Bassa/Media	Verifica validità immobili, chiamate asincrone/sincrone.
Utente Esterno → DB Off-Chain	Mai (No)	Nulla	Deviazione topologica grave (violazione segmentazione).
Security Gateway → Backup Storage	Notte (Sì)	Alta	Sincronizzazione pianificata dei dati Off-Chain.

Tabella 6: Baseline qualitativa dei flussi leciti (Operating Envelope).

5.2 Finestra di Telemetria Osservata (Dataset di Esempio)

Si considera una finestra temporale campione con log estratti da firewall e Security Gateway.

Time	Source	Dest	Proto	Pkts	Status
10:15	Frontend Web (IP vari)	Security Gateway	HTTPS	340	ok
10:16	Security Gateway	DB Off-Chain	TCP	510	ok
10:17	Security Gateway	API Catasto	HTTPS	15	ok
10:18	IP Pubblico (sconosciuto)	DB Off-Chain	TCP	45	fail
10:20	Frontend Web (singolo IP)	Security Gateway	HTTPS	850	retry
03:05	Security Gateway	Backup Storage	TCP	1500	ok
03:10	Security Gateway	IP Pubblico (sconosciuto)	HTTPS	2200	ok

Tabella 7: Finestra di telemetria osservata per la classificazione delle deviazioni.

5.3 Valutazione Deviazioni e Classificazione

Gli eventi non pienamente compatibili con la baseline vengono classificati con severità e motivazione.

Evento	CompatibileScore		Classificazione	Dato utile (giustificazione)
10:18 IP Pubblico → DB	No	Forte	Attacco	Log firewall: violazione grave della segmentazione. Il DB non deve ricevere traffico diretto dall'esterno.
10:20 Frontend → Gateway	No	Medio	Fault / Attacco	Log autenticazione API: anomalia volumetrica da singolo IP. Possibile credential stuffing oppure errore client.
03:05 Gateway → Backup	Parziale	Lieve	Unknown	Log schedulazione: trasferimento massivo atteso di notte, ma senza audit completo resta non conclusivo.
03:10 Gateway → IP Sconosciuto	No	Forte	Attacco	Ispezione connessioni: invio dati verso destinazione esterna non censita. Forte indicatore di data exfiltration.

Tabella 8: Classificazione delle deviazioni rispetto alla baseline comportamentale.

5.4 Debrief Finale di Sicurezza

Asset più critico e deviazione più grave. L'asset più critico resta lo **Smart Contract** su Fabric, poiché governa transazioni irreversibili di valore e proprietà. Le deviazioni più gravi osservate sono:

- 03:10 Gateway → IP Sconosciuto
- 10:18 IP Pubblico → DB

Entrambe indicano potenziale data breach e fallimento dei controlli perimetrali di base.

Deviazione più ambigua. 10:20 Frontend → Gateway è ambigua: può essere un *fault* applicativo (retry anomali) oppure un brute-force mirato. Senza log applicativi dettagliati, la decisione non è deterministica.

Quando la risposta corretta è “Unknown”. Nel caso 03:05 Gateway → Backup, il volume elevato notturno è coerente con job leciti di backup ma, in assenza di evidenze di audit, la classificazione prudente resta **Unknown** per ridurre falsi positivi.

Controllo by-design prioritario. La **Network Segmentation** rigorosa (DMZ + reti virtuali isolate) riduce i falsi negativi e limita il blast radius. In questo modello, eventi come IP Pubblico → DB devono essere bloccati nativamente dal perimetro (*default deny*).

“Detection non significa indovinare attacchi. Significa ridurre l’incertezza fino a una decisione difendibile.”